

Vulnerability Audit and Assessment – Results and Executive Summary

1. Introduction

Before launching tool-based scans, a manual review of <http://demo.testfire.net> revealed key weaknesses:

- Weak credentials accepted without rate-limiting
- Sensitive account details displayed openly
- Poor session control and lack of logout option

The site, known as Altoro Mutual, is a deliberately vulnerable online banking demo used for penetration testing training. It includes features like login, fund transfer, and transaction history making it ideal for simulating real-world attacks.

Kali Linux on VMware Fusion Pro (MacBook) was used to identify vulnerabilities across web, OS, middleware, and network layers, assessing security posture and compliance with GDPR and PCI DSS v4.0.

2. Methodology Summary

A mix of automated and manual tools was used to assess demo.testfire.net. The approach included scanning for vulnerabilities in web apps, SSL/TLS, DNS, and server infrastructure.

Tool	Purpose	Outcome
Nmap	Network and port scanner to detect open ports and services	Discovered open ports: 80 (HTTP), 443 (HTTPS), 139/445 (SMB), 8080 (proxy). SMB ports were flagged as unnecessary and a risk vector for lateral movement attacks
Nikto	Web server vulnerability scanner to detect outdated software and common exploits	Identified outdated Apache version, XSS risk, and exposed sensitive paths
OWASP ZAP	Automated web vulnerability scanner for runtime analysis	Detected missing CSRF tokens, outdated TLS version, and absent security headers
Burp Suite	Manual testing proxy to intercept, manipulate, and scan HTTP/S requests	Confirmed session fixation vulnerabilities and authentication weaknesses
SSLyze	Tool to assess SSL/TLS configuration compliance	TLS 1.0 still enabled, weak ciphers supported, and expired certificate found
WHOIS/DIG	Network intelligence tools to analyze DNS and ownership data	Found missing SPF/DKIM/DMARC policies and outdated certificate info
Traceroute	Visualized the routing path to assess exposure points	Confirmed the route and potential exposure from intermediate hops

Below are the screenshots of the tests performed:

1. Nmap Scan Results with Traceroute for demo.testfire.net

```
sniffer@kali: ~/Desktop
$ nmap -A demo.testfire.net -oN nmap_output.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2025-05-28 19:27 IST
Nmap scan report for demo.testfire.net (65.61.137.117)
Host is up (0.25s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache Tomcat/Coyote JSP engine 1.1
|_http-server-header: Apache-Coyote/1.1
|_http-title: Altoro Mutual
443/tcp    open  ssl/http  Apache Tomcat/Coyote JSP engine 1.1
|_ssl-cert: Subject: commonName=demo.testfire.net
|_Subject Alternative Name: DNS:demo.testfire.net, DNS:altoromutual.com
|_Not valid before: 2024-06-03T00:00:00
|_Not valid after: 2025-07-04T23:59:59
|_http-title: Altoro Mutual
|_http-server-header: Apache-Coyote/1.1
|_ssl-date: 2025-05-28T13:58:45+00:00; 0s from scanner time.
8080/tcp   open  http      Apache Tomcat/Coyote JSP engine 1.1
|_http-title: Altoro Mutual
|_http-server-header: Apache-Coyote/1.1
8443/tcp   closed https-alt
Device type: general purpose
Running (JUST GUESSING): Microsoft Windows 2008/7/2016/10 (92%), FreeBSD 6.X (88%)
OS CPE: cpe:/o:microsoft:windows_server_2008:r2 cpe:/o:microsoft:windows_8 cpe:/o:microsoft:windows_7 cpe:/o:freebsd:freebsd:6.2 cpe:/o:microsoft:windows_server_2016 cpe:/o:microsoft:windows_10
Aggressive OS guesses: Microsoft Windows Server 2008 R2 or Windows 8 (92%), Microsoft Windows Server 2008 R2 or Windows 7 SP1 (90%), Microsoft Windows Server 2008 R2 SP1 or Windows 8 (89%), FreeBSD 6.2-RELEASE (88%), Microsoft Windows 7 or Windows Server 2008 R2 (88%), Microsoft Windows Server 2016 (88%), Microsoft Windows Server 2008 R2 (88%), Microsoft Windows 7 (87%), Microsoft Windows 10 1607 (86%), Microsoft Windows Server 2008 R2 SP1 (85%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 25 hops

TRACEROUTE (using port 8443/tcp)
HOP RTT ADDRESS
1 5.89 ms 192.168.0.1
2 6.58 ms 10.51.53.3
3 ... 4
5 9.25 ms 14.143.171.25.static-pune.vsnl.net.in (14.143.171.25)
6 10.76 ms 172.28.118.237
7 13.85 ms ix-ae-0-100.tcore1.mlv-mumbai.as6453.net (180.87.38.5)
8 149.85 ms if-ae-32-2.tcore2.mlv-mumbai.as6453.net (180.87.38.147)
9 ...
10 152.93 ms if-bundle-29-2.qcore5.ldn-london.as6453.net (80.231.76.127)
11 146.24 ms if-bundle-51-2.qcore2.ldn-london.as6453.net (195.219.16.136)
12 147.85 ms 195.219.16.139
```

```
|_http-server-header: Apache-Coyote/1.1
|_ssl-date: 2025-05-28T13:58:45+00:00; 0s from scanner time.
8080/tcp   open  http      Apache Tomcat/Coyote JSP engine 1.1
|_http-title: Altoro Mutual
|_http-server-header: Apache-Coyote/1.1
8443/tcp   closed https-alt
Device type: general purpose
Running (JUST GUESSING): Microsoft Windows 2008/7/2016/10 (92%), FreeBSD 6.X (88%)
OS CPE: cpe:/o:microsoft:windows_server_2008:r2 cpe:/o:microsoft:windows_8 cpe:/o:microsoft:windows_7 cpe:/o:freebsd:freebsd:6.2 cpe:/o:microsoft:windows_server_2016 cpe:/o:microsoft:windows_10
Aggressive OS guesses: Microsoft Windows Server 2008 R2 or Windows 8 (92%), Microsoft Windows Server 2008 R2 or Windows 7 SP1 (90%), Microsoft Windows Server 2008 R2 SP1 or Windows 8 (89%), FreeBSD 6.2-RELEASE (88%), Microsoft Windows 7 or Windows Server 2008 R2 (88%), Microsoft Windows Server 2016 (88%), Microsoft Windows Server 2008 R2 (88%), Microsoft Windows 7 (87%), Microsoft Windows 10 1607 (86%), Microsoft Windows Server 2008 R2 SP1 (85%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 25 hops

TRACEROUTE (using port 8443/tcp)
HOP RTT ADDRESS
1 5.89 ms 192.168.0.1
2 6.58 ms 10.51.53.3
3 ... 4
5 9.25 ms 14.143.171.25.static-pune.vsnl.net.in (14.143.171.25)
6 10.76 ms 172.28.118.237
7 13.85 ms ix-ae-0-100.tcore1.mlv-mumbai.as6453.net (180.87.38.5)
8 149.85 ms if-ae-32-2.tcore2.mlv-mumbai.as6453.net (180.87.38.147)
9 ...
10 152.93 ms if-bundle-29-2.qcore5.ldn-london.as6453.net (80.231.76.127)
11 146.24 ms if-bundle-51-2.qcore2.ldn-london.as6453.net (195.219.16.136)
12 147.85 ms 195.219.16.139
13 ... 16
17 280.84 ms ae14.cr1.dfw1.us.zip.zayo.com (64.125.19.20)
18 ...
19 305.00 ms ae6.er3.dfw2.us.zip.zayo.com (64.125.26.55)
20 246.74 ms 64.125.46.126.IPYX-172935-900-ZYO.zip.zayo.com (64.125.46.126)
21 ...
22 251.11 ms core0-dcp3.dfw1.rackspace.net (148.62.41.101)
23 304.47 ms core10-corec.dfw1.rackspace.net (148.62.41.135)
24 308.24 ms core9-aggr171b-8.dfw3.rackspace.net (74.205.108.91)
25 248.41 ms 65.61.137.117

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 58.26 seconds

sniffer@kali: ~/Desktop
```

The above screenshots show the result of the following command executed in a Kali Linux terminal:

Nmap (Network Mapping and Traceroute)

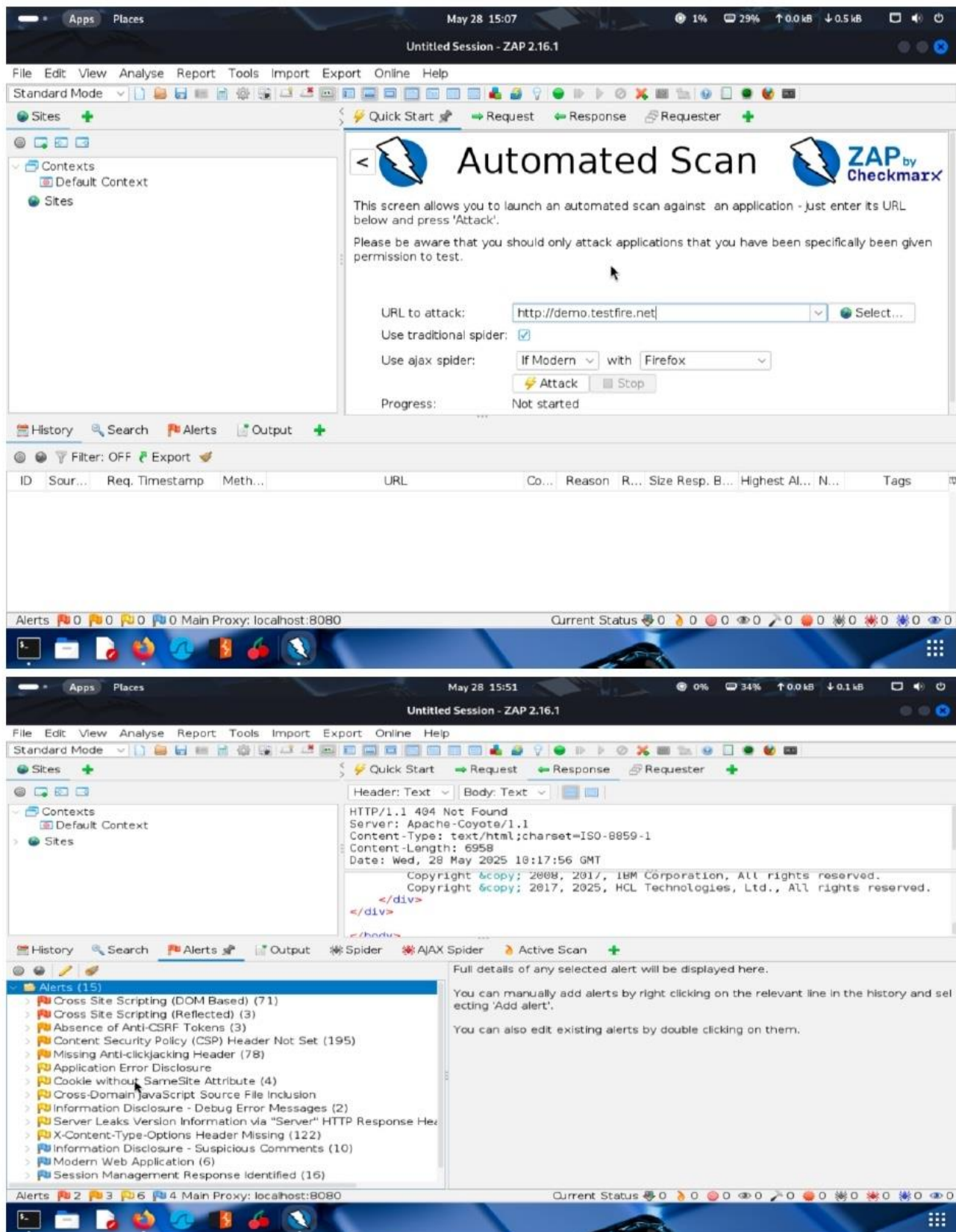
Nmap was chosen for its comprehensive network scanning capabilities, including service detection, OS fingerprinting, and traceroute mapping. It identified open ports (80, 443, 8080) and SMB ports (139, 445), which are atypical for public servers and increase the risk of lateral movement. The scan also revealed outdated services such as Apache Tomcat/Coyote JSP and potentially unsupported OS versions like Windows Server 2008. Traceroute exposed the multi-hop network path, confirming infrastructure complexity and interception possibilities. These findings are critical as they signal violations of GDPR Article 32 and PCI DSS Requirement 1, which mandate secure configurations and restricted network exposure.

2. Nikto scan results on demo.testfire.net

```
sniffer@kali: ~  
$ nikto -h http://demo.testfire.net -Display V  
- Nikto v2.5.0  
-----  
V:Wed May 28 14:30:31 2025 - Initialising plugin nikto_headers  
V:Wed May 28 14:30:31 2025 - Loaded "HTTP Headers" plugin.  
V:Wed May 28 14:30:31 2025 - Initialising plugin nikto_dictionary_attack  
V:Wed May 28 14:30:31 2025 - Loaded "Dictionary attack" plugin.  
V:Wed May 28 14:30:31 2025 - Initialising plugin nikto_report_csv  
V:Wed May 28 14:30:31 2025 - Loaded "CSV reports" plugin.  
V:Wed May 28 14:30:31 2025 - Initialising plugin nikto_parked  
V:Wed May 28 14:30:31 2025 - Loaded "Parked Detection" plugin.  
V:Wed May 28 14:30:31 2025 - Initialising plugin nikto_report_sqlg  
V:Wed May 28 14:30:31 2025 - Loaded "Generic SQL reports" plugin.  
V:Wed May 28 14:30:31 2025 - Initialising plugin nikto_outdated  
V:Wed May 28 14:30:31 2025 - Loaded "Outdated" plugin.  
V:Wed May 28 14:30:31 2025 - Initialising plugin nikto_fileops  
V:Wed May 28 14:30:31 2025 - Loaded "File Operations" plugin.  
V:Wed May 28 14:30:31 2025 - Initialising plugin nikto_embedded  
V:Wed May 28 14:30:31 2025 - Loaded "Embedded Detection" plugin.  
V:Wed May 28 14:30:31 2025 - Initialising plugin nikto_ms10_070  
V:Wed May 28 14:30:31 2025 - Loaded "ms10-070 Check" plugin.  
V:Wed May 28 14:30:31 2025 - Initialising plugin nikto_drupal  
V:Wed May 28 14:30:31 2025 - Loaded "Drupal Specific Tests" plugin.  
V:Wed May 28 14:30:31 2025 - Initialising plugin nikto_negotiate  
V:Wed May 28 14:30:31 2025 - Loaded "Negotiate" plugin.  
V:Wed May 28 14:30:31 2025 - Initialising plugin nikto_report_nbe  
V:Wed May 28 14:30:31 2025 - Loaded "NBE reports" plugin.  
V:Wed May 28 14:30:31 2025 - Initialising plugin nikto_siebel  
V:Wed May 28 14:30:31 2025 - Loaded "Siebel Checks" plugin.  
V:Wed May 28 14:30:31 2025 - Initialising plugin nikto_sitefiles  
V:Wed May 28 14:30:31 2025 - Loaded "Site files" plugin.  
V:Wed May 28 14:30:31 2025 - Initialising plugin nikto_content_search  
V:Wed May 28 14:30:31 2025 - Loaded "Content Search" plugin.  
V:Wed May 28 14:30:31 2025 - Initialising plugin nikto_docker_registry  
V:Wed May 28 14:30:31 2025 - Loaded "docker_registry" plugin.  
V:Wed May 28 14:30:31 2025 - Initialising plugin nikto_report_text  
V:Wed May 28 14:30:31 2025 - Loaded "Text reports" plugin.  
V:Wed May 28 14:30:31 2025 - Initialising plugin nikto_report_json
```

```
sniffer@kali: ~  
V:Wed May 28 14:30:31 2025 - Running start for "IBM/Lotus Domino Specific Tests" plugin  
V:Wed May 28 14:30:31 2025 - Running start for "Favicon" plugin  
V:Wed May 28 14:30:31 2025 - Running start for "Content Search" plugin  
V:Wed May 28 14:30:31 2025 - Running start for "Test Authentication" plugin  
V:Wed May 28 14:30:31 2025 - Checking for HTTP on demo.testfire.net:80, using GET  
V:Wed May 28 14:30:32 2025 - 200 for GET: /  
+ Target IP: 65.61.137.117  
+ Target Hostname: demo.testfire.net  
+ Target Port: 80  
+ Start Time: 2025-05-28 14:30:32 (GMT5.5)  
-----  
+ Server: Apache-Coyote/1.1  
V:Wed May 28 14:30:32 2025 - 200 for GET: /  
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options  
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the  
HTML type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/  
V:Wed May 28 14:30:32 2025 - Testing error for file: /jr2JAue0.10:100  
V:Wed May 28 14:30:32 2025 - 404 for GET: /jr2JAue0.10:100  
V:Wed May 28 14:30:32 2025 - Testing error for file: /jr2JAue0.box  
V:Wed May 28 14:30:33 2025 - 404 for GET: /jr2JAue0.box  
V:Wed May 28 14:30:33 2025 - Testing error for file: /jr2JAue0.mediawiki  
V:Wed May 28 14:30:33 2025 - 404 for GET: /jr2JAue0.mediawiki  
V:Wed May 28 14:30:33 2025 - Testing error for file: /jr2JAue0.apw  
V:Wed May 28 14:30:33 2025 - 404 for GET: /jr2JAue0.apw  
V:Wed May 28 14:30:33 2025 - Testing error for file: /jr2JAue0.html+  
V:Wed May 28 14:30:34 2025 - 404 for GET: /jr2JAue0.html+  
V:Wed May 28 14:30:34 2025 - Testing error for file: /jr2JAue0.dll  
V:Wed May 28 14:30:34 2025 - 404 for GET: /jr2JAue0.dll  
V:Wed May 28 14:30:34 2025 - Testing error for file: /jr2JAue0.grp  
V:Wed May 28 14:30:34 2025 - 404 for GET: /jr2JAue0.grp  
V:Wed May 28 14:30:34 2025 - Testing error for file: /jr2JAue0.cs  
V:Wed May 28 14:30:35 2025 - 404 for GET: /jr2JAue0.cs  
V:Wed May 28 14:30:35 2025 - Testing error for file: /jr2JAue0.JSP  
V:Wed May 28 14:30:35 2025 - 404 for GET: /jr2JAue0.JSP  
V:Wed May 28 14:30:35 2025 - Testing error for file: /jr2JAue0.dtd  
V:Wed May 28 14:30:35 2025 - 404 for GET: /jr2JAue0.dtd  
V:Wed May 28 14:30:35 2025 - Testing error for file: /jr2JAue0.bas:ShowVolume  
V:Wed May 28 14:30:36 2025 - 404 for GET: /jr2JAue0.bas:ShowVolume
```


3. OWASP ZAP Scan Results for demo.testfire.net



The image displays two screenshots of the OWASP ZAP 2.16.1 interface, showing the process of performing an automated scan and the resulting alerts.

Top Screenshot: Automated Scan

The interface shows the "Automated Scan" screen. The URL to attack is set to `http://demo.testfire.net`. The "Use traditional spider" checkbox is checked. The "Use ajax spider" dropdown is set to "If Modern" with "Firefox" selected. The "Attack" button is visible. The progress is "Not started".

Bottom Screenshot: Alerts

The interface shows the "Alerts" list. The "Alerts" tab is selected, showing 15 alerts. The "Alerts" list is expanded, showing the following alerts:

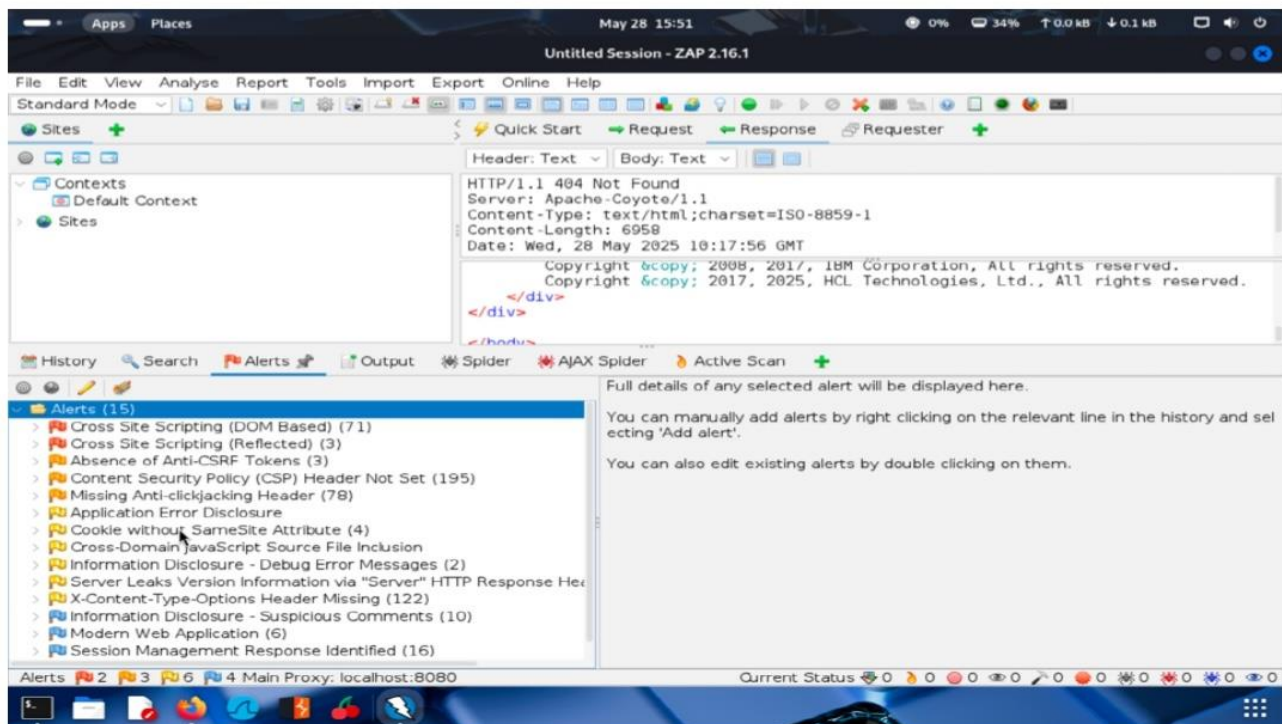
- Cross Site Scripting (DOM Based) (71)
- Cross Site Scripting (Reflected) (3)
- Absence of Anti-CSRF Tokens (3)
- Content Security Policy (CSP) Header Not Set (195)
- Missing Anti-clickjacking Header (78)
- Application Error Disclosure
- Cookie without SameSite Attribute (4)
- Cross-Domain JavaScript Source File Inclusion
- Information Disclosure - Debug Error Messages (2)
- Server Leaks Version Information via "Server" HTTP Response Header
- X-Content-Type-Options Header Missing (122)
- Information Disclosure - Suspicious Comments (10)
- Modern Web Application (6)
- Session Management Response Identified (16)

The "Alerts" list is expanded, showing the following details for the selected alert:

Full details of any selected alert will be displayed here.

You can manually add alerts by right clicking on the relevant line in the history and selecting 'Add alert'.

You can also edit existing alerts by double clicking on them.

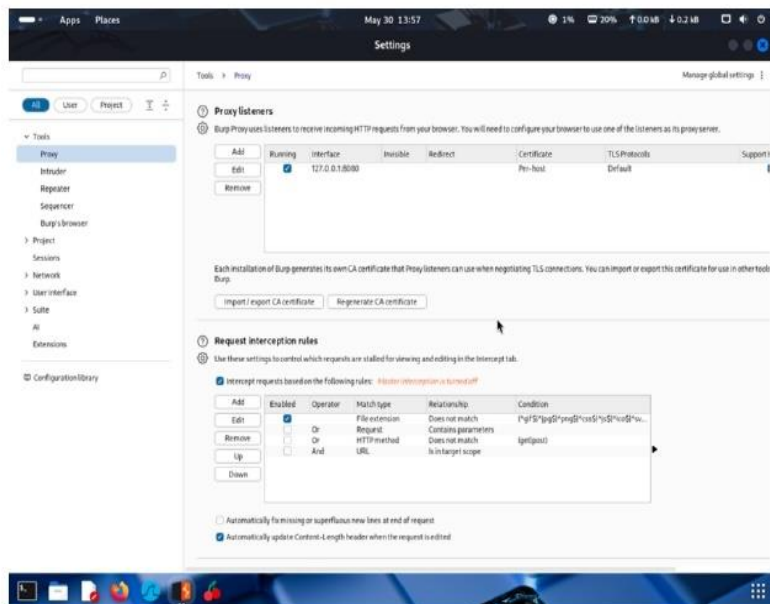


The screenshots above show the automated scan conducted using **OWASP ZAP (Zed Attack Proxy)**, a leading open-source web application scanner widely used in penetration testing and DevSecOps pipelines. The scan was initiated through ZAP's **Quick Start panel**, where the target URL `http://demo.testfire.net` was entered, and the active scan was launched using both traditional and AJAX spiders.

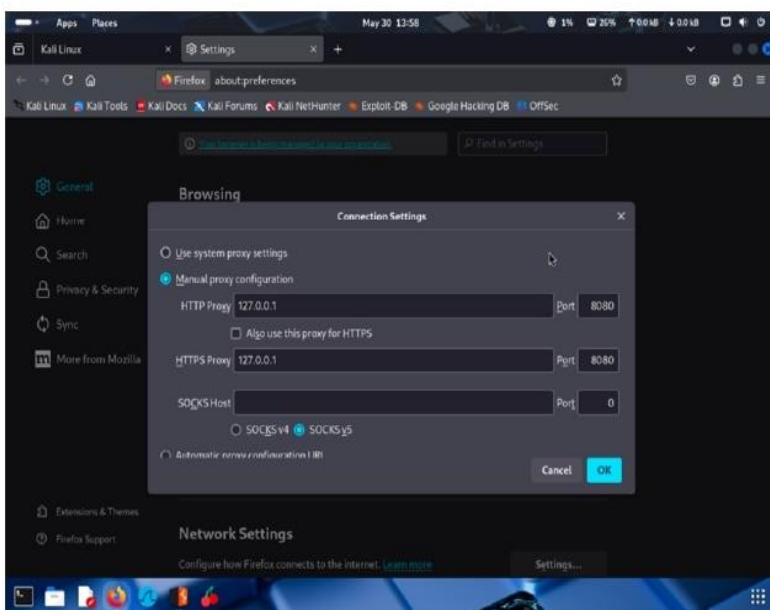
OWASP ZAP (Dynamic Application Security Testing)

OWASP ZAP was used to automate runtime analysis of the application. It successfully detected DOM-based and reflected XSS, missing CSRF tokens, and weak security headers including the absence of CSP and SameSite attributes. These misconfigurations reduce the application's ability to prevent browser-based attacks such as clickjacking and session hijacking. The tool mimics real-world attack behavior, providing insights into runtime response to malformed inputs and insecure configurations. Violations of GDPR Articles 25 and 32, along with PCI DSS 6.5, were observed as the application failed to implement standard protections.

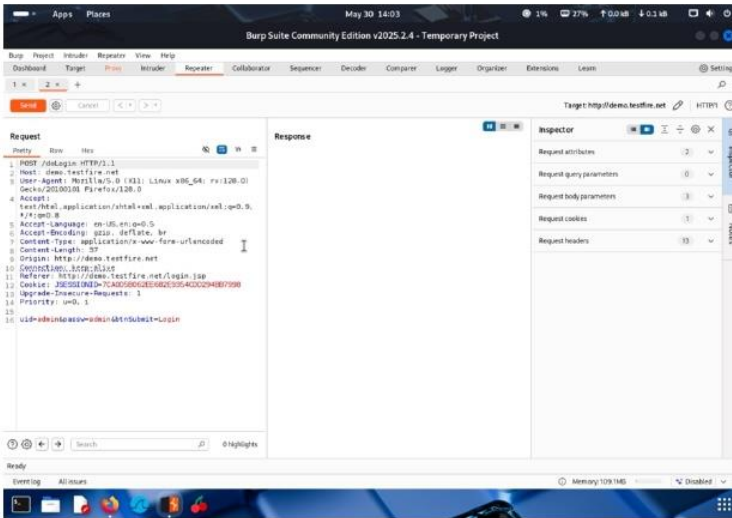
4. Burp Suite Scan – Manual Analysis



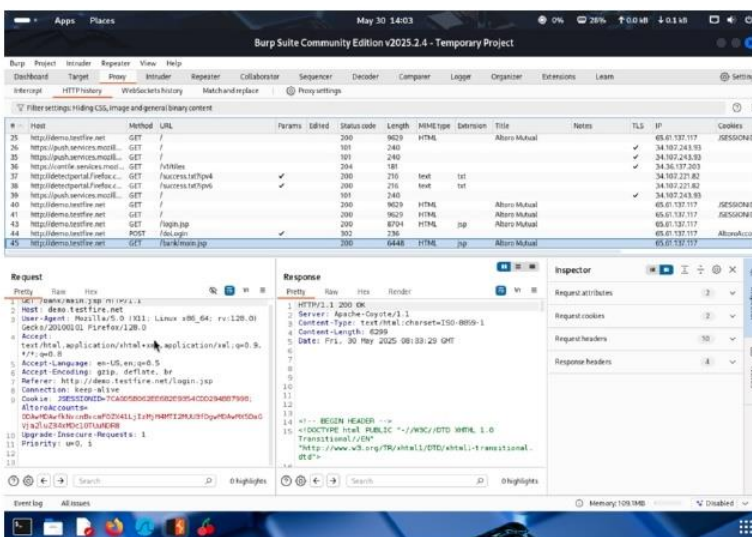
Burp Proxy Listener Setup: This shows the proxy listener configured at 127.0.0.1:8080, allowing Burp Suite to intercept browser traffic for analysis.



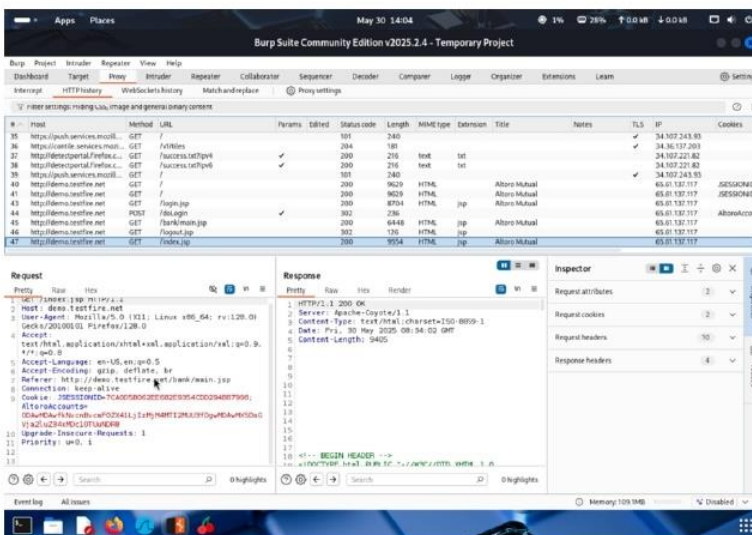
Firefox Proxy Configuration for Burp Suite: The browser was configured to route all HTTP and HTTPS traffic through Burp Suite's proxy at 127.0.0.1:8080, enabling interception and inspection of requests.



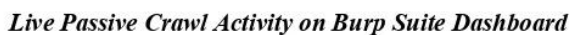
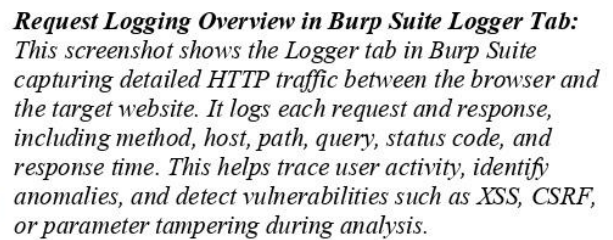
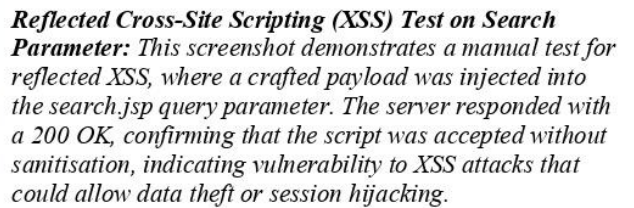
Repeater Test of Login Request with Default Credentials:
This screenshot from Burp Suite's Repeater tool shows a manual POST request sent to /doLogin using the credentials admin:admin. The request successfully authenticates, indicating weak authentication controls and lack of rate limiting or account lockout.



HTTP History Showing GET Request to Bank Page After Login:
This screenshot from Burp Suite shows a GET request made to /bank/main.jsp after successful login. The response confirms that the session remains active and exposes sensitive user-related content, indicating poor session management practices.



GET Request to Homepage Post Login:
This screenshot captures a follow-up GET request to /index.jsp, which occurred after navigating from the authenticated banking section. The request continues using the same session ID and cookie, suggesting that session tokens persist across multiple pages, which if not secured properly, can expose users to session hijacking.

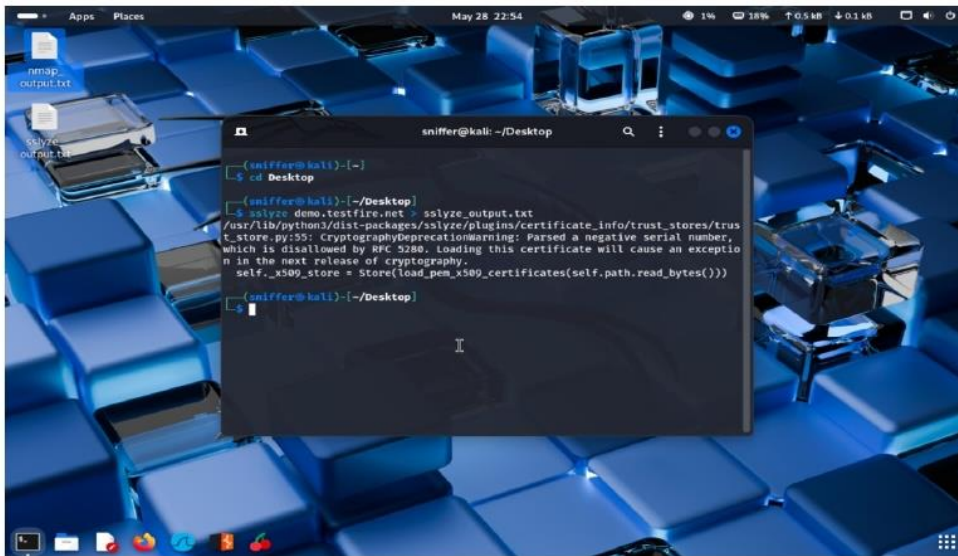


This screenshot highlights Burp Suite's Dashboard where a "Live passive crawl from Proxy" task was actively capturing and mapping all HTTP traffic. It added numerous items to the sitemap by analyzing inbound and outbound communication. This feature is instrumental in creating a visual structure of the target website's attack surface and helps uncover hidden endpoints without active scanning.

Burp Suite (Manual Proxy-Based Testing)

Burp Suite was chosen for in-depth manual testing to intercept and manipulate HTTP/HTTPS traffic. The tool was configured with a local proxy and integrated into Firefox ESR. Repeater and Logger modules were used to test authentication mechanisms, validate session tokens, and inspect HTTP responses. Notable vulnerabilities included successful login with default credentials, session tokens persisting across requests, and reflected XSS via the search endpoint. Passive crawling generated a comprehensive sitemap, exposing additional endpoints. These findings point to inadequate input handling and session management, breaching GDPR Article 32 and PCI DSS 6.5.

5. SSLyze Scan Output

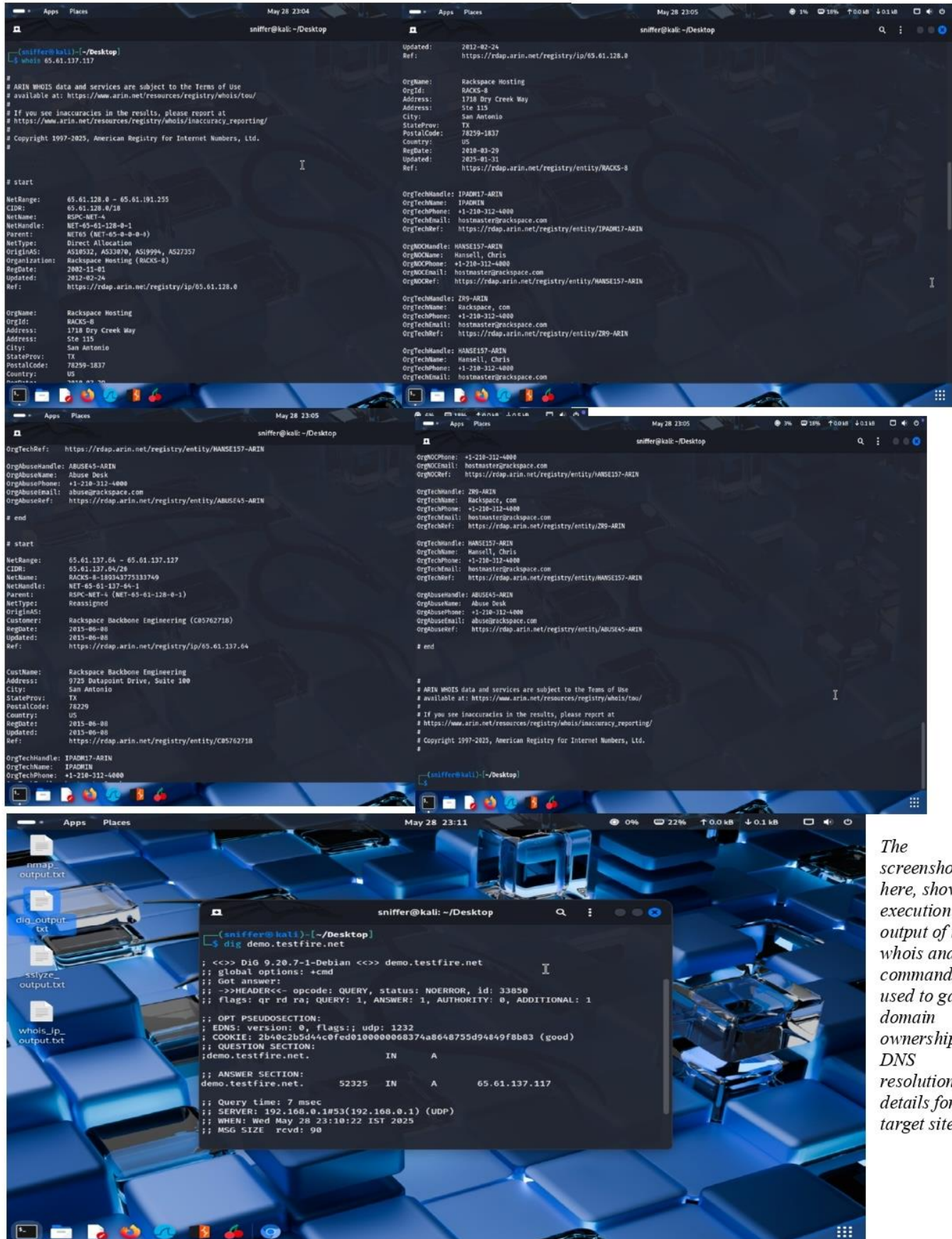


The screenshot above shows the execution of the SSLyze tool, which was used to analyze the SSL/TLS configuration of the target web server `demo.testfire.net`. The command used was: `sslyze demo.testfire.net > sslyze_output.txt`

SSLyze (TLS/SSL Configuration Assessment)

SSLyze was used to inspect the security posture of SSL/TLS encryption. It detected support for deprecated protocols such as TLS 1.0 and flagged a non-compliant certificate serial number, which may cause rejection in modern cryptographic libraries. These outdated settings highlight poor encryption practices and a failure to follow cryptographic hygiene, which undermines secure data transmission. The findings signal non-compliance with GDPR Article 32 and PCI DSS v4.0 Requirements 4 and 6.

6. WHOIS and DIG Analysis of demo.testfire.net



The screenshots show a Kali Linux desktop environment with a terminal window. The first screenshot shows the execution of the `whois` command, displaying ARIN WHOIS data for the IP range 65.61.128.0. The second screenshot shows the execution of the `whois` command again, displaying ARIN WHOIS data for the IP range 65.61.128.0. The third screenshot shows the execution of the `dig` command, displaying DNS resolution details for demo.testfire.net. The fourth screenshot shows the execution of the `dig` command again, displaying DNS resolution details for demo.testfire.net.

```
(sniffer@kali) ~/Desktop
$ whois 65.61.128.0

# ARIN WHOIS data and services are subject to the Terms of Use
# available at: https://www.arin.net/resources/registry/whois/tou/
#
# If you see inaccuracies in the results, please report at
# https://www.arin.net/resources/registry/whois/inaccuracy_reporting/
#
# Copyright 1997-2025, American Registry for Internet Numbers, Ltd.

# start

NetRange: 65.61.128.0 - 65.61.191.255
CIDR: 65.61.128.0/28
NetName: RSPC-NET-4
NetHandle: NET-65-61-128-0-1
Parent: NET65 (NET-65-0-0-0-1)
NetType: Direct Allocation
OrigAs: AS18932, AS32070, AS19994, AS27357
Organization: Rackspace Hosting (RACKS-8)
RegDate: 2002-11-01
Updated: 2012-02-24
Ref: https://rdap.arin.net/registry/ip/65.61.128.0

OrgName: Rackspace Hosting
OrgId: RACKS-8
Address: 1718 Dry Creek Way
Address: Ste 115
City: San Antonio
StateProv: TX
PostalCode: 78259-1837
Country: US
RegDate: 2010-08-20
Updated: 2025-01-31
Ref: https://rdap.arin.net/registry/entity/RACKS-8

OrgTechHandle: IPADM17-ARIN
OrgTechName: IPADM17
OrgTechPhone: +1-210-312-4000
OrgTechEmail: hostmaster@rackspace.com
OrgTechRef: https://rdap.arin.net/registry/entity/IPADM17-ARIN

OrgMOCHandle: HANSE157-ARIN
OrgMOCHandle: HANSELL, Chris
OrgMOCHandlePhone: +1-210-312-4000
OrgMOCHandleEmail: hostmaster@rackspace.com
OrgMOCHandleRef: https://rdap.arin.net/registry/entity/HANSE157-ARIN

OrgTechHandle: Z99-ARIN
OrgTechName: Rackspace, com
OrgTechPhone: +1-210-312-4000
OrgTechEmail: hostmaster@rackspace.com
OrgTechRef: https://rdap.arin.net/registry/entity/Z99-ARIN

OrgTechHandle: HANSE157-ARIN
OrgTechName: HANSELL, Chris
OrgTechPhone: +1-210-312-4000
OrgTechEmail: hostmaster@rackspace.com

OrgAbuseHandle: ABUSE45-ARIN
OrgAbuseName: Abuse Desk
OrgAbusePhone: +1-210-312-4000
OrgAbuseEmail: abuse@rackspace.com
OrgAbuseRef: https://rdap.arin.net/registry/entity/ABUSE45-ARIN

# end

# start

NetRange: 65.61.127.0 - 65.61.137.127
CIDR: 65.61.127.0/28
NetName: RACKS-8-18934377533749
NetHandle: NET-65-61-127-0-1
Parent: RSPC-NET-4 (NET-65-61-128-0-1)
NetType: Reassigned
OrigAs:
Customer: Rackspace Backbone Engineering (C85762718)
RegDate: 2015-06-08
Updated: 2015-06-08
Ref: https://rdap.arin.net/registry/ip/65.61.137.64

CustName: Rackspace Backbone Engineering
Address: 9725 Datapoint Drive, Suite 100
City: San Antonio
StateProv: TX
PostalCode: 78229
Country: US
RegDate: 2015-06-08
Updated: 2015-06-08
Ref: https://rdap.arin.net/registry/entity/C85762718

OrgTechHandle: IPADM17-ARIN
OrgTechName: IPADM17
OrgTechPhone: +1-210-312-4000

(sniffer@kali) ~/Desktop

$ dig demo.testfire.net

; <<>> DiG 9.20.7-1-Debian <<>> demo.testfire.net
;; global options: +cmd
;; Got answer:
;; ->HEADER<<- opcode: QUERY, status: NOERROR, id: 33050
;; flags: qr rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
;; EDNS: version: 0, flags: udp: 1232
;; COOKIE: 2b40c2b5d4c0fed0100000068374a864875d94649f8b83 (good)
;; QUESTION SECTION:
;demo.testfire.net. IN A
;; ANSWER SECTION:
demo.testfire.net. 52325 IN A 65.61.137.117

;; Query time: 7 msec
;; SERVER: 192.168.0.1#53(192.168.0.1) (UDP)
;; WHEN: Wed May 28 23:10:22 IST 2025
;; MSG SIZE rcvd: 90
```

The screenshots here, show the execution and output of the whois and dig commands, used to gather domain ownership and DNS resolution details for the target site.

WHOIS and DIG (DNS and Ownership Reconnaissance)

WHOIS and DIG were utilized to gather domain metadata and validate DNS resolution. WHOIS confirmed the domain’s hosting provider (Rackspace), registrar details, and abuse reporting contacts, while DIG revealed the IP mapping for demo.testfire.net. These tools offer early-stage intelligence and were critical in validating the legitimacy of the environment before testing. Although they don’t identify vulnerabilities directly, they facilitate informed target scoping and legal reporting procedures.

Summary of Tool-Based Analysis

The selected tools provided a comprehensive assessment of demo.testfire.net. Network utilities (Nmap, DIG) uncovered open ports and resolution paths; web scanners (Nikto, ZAP, Burp Suite) revealed injection flaws, missing headers, and session issues; and SSLyze highlighted encryption and certificate weaknesses. Collectively, these tools exposed GDPR and PCI DSS non-compliance, forming a solid basis for actionable improvements.

Limitations Encountered

To maintain ethical and scoped testing, several boundaries were respected:

- **Authenticated Testing Scope:** Though default credentials (admin/admin) worked, deeper role-based enumeration was avoided to prevent changes or policy violations.
- **Tool Constraints:** Some tools (e.g., Nikto, SSLyze) offer limited depth versus commercial options and may lack contextual risk scoring or exploit chaining.
- **Ethical Restrictions:** DoS, brute-force, or destructive payloads were excluded to preserve system availability and uphold terms of use.
- **Privilege Escalation:** Though admin access was available, privilege escalation was not attempted to remain within ethical bounds.

These constraints ensured responsible testing while still uncovering critical GDPR and PCI DSS vulnerabilities.

3. Findings Summary (Non-Technical)

This section outlines the key security issues identified during testing in plain terms to help non-technical stakeholders understand their potential impact on business operations and customer trust.

Issue Detected	Description	Business Impact
Outdated Apache	The server version has known exploits	Easier target for attackers
No CSRF Protection	Web forms can be abused	Users may be tricked into unintended actions
Missing HTTP Headers	No X-Frame-Options or HSTS	Enables clickjacking and downgrade attacks
Weak TLS Configuration	TLS 1.0 still enabled	Fails GDPR's data protection clause
SMB Ports Open	Ports 139/445 exposed	Enables lateral movement or OS exploits
Session Fixation	Tokens reused between sessions	Account hijacking risk
Missing SPF/DMARC	No DNS protection for email	Easier for attackers to spoof emails
Expired SSL Certificate	TLS cert expired	Trust and data security compromised

Each issue poses a risk to business continuity, data protection, or regulatory compliance. Exploitation of these vulnerabilities could result in unauthorised access, data breaches, financial fraud, or damage to reputation. Timely remediation is essential to protect customer data and avoid legal or financial penalties.

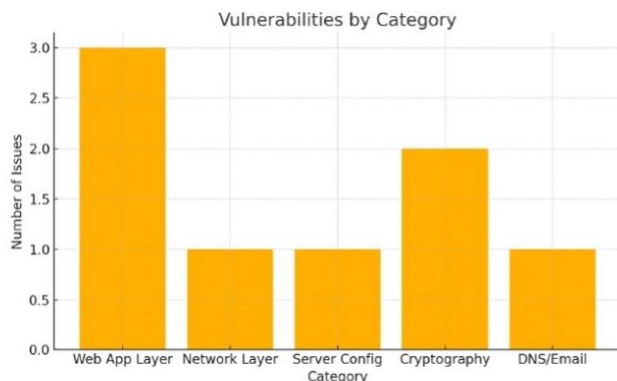


Figure 1: Vulnerabilities by Category
This chart categorises the identified vulnerabilities across various layers—web application, network, server configuration, cryptography, and DNS/email security. It visually highlights that most issues are located at the web application layer, reinforcing the need for robust application-level hardening.

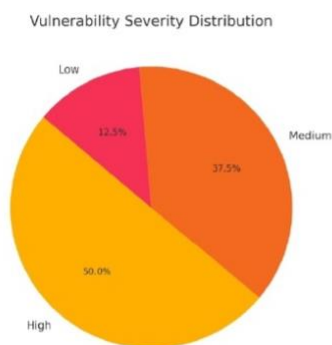


Figure 2: How Serious the Security Issues Are

This chart shows how severe each security issue is, grouped into high, medium, and low categories. High-level issues—like outdated software and weak security settings—should be fixed right away to protect your customers and business. Medium and low issues are still important but can be handled a little later based on your schedule and budget.

4. OWASP Top 10 vs. Non-OWASP Vulnerabilities

The identified vulnerabilities fall into two categories: those defined in the OWASP Top 10 (focused on application-level flaws), and others affecting infrastructure and system configuration.

OWASP Top 10 Issues Detected:

- **A5:2021** – Security Misconfiguration (e.g., missing headers)
- **A6:2021** – Vulnerable & Outdated Components (e.g., Apache server)
- **A7:2021** – Identification & Authentication Failures (session fixation)
- **A9:2021** – Logging & Monitoring Failures (no evidence of security logging)

Non-OWASP Issues Identified:

- TLS misconfiguration (SSLyze)
- Missing SPF/DMARC records (WHOIS/DIG)
- SMB port exposure (Nmap)
- Expired SSL certificates

While OWASP vulnerabilities compromise application-level security, the non-OWASP findings highlight architectural and operational risks that require system-level remediation. Together, these gaps weaken the organisation's overall security posture and increase the likelihood of both technical and regulatory breaches.

5. Evaluation Against Standards



Compliance Mapping of Detected Vulnerabilities: This chart breaks down how many of the identified issues violate GDPR, PCI DSS, or general best practices. It helps business stakeholders prioritise fixes based on regulatory exposure.

Compliance Mapping of Detected Vulnerabilities:

The chart above illustrates how each issue maps to GDPR, PCI DSS v4.0, or industry best practices. This visual helps prioritise fixes based on regulatory and operational exposure.

General Data Protection Regulation (GDPR)

- **Article 32** requires data protection through encryption and system integrity.
- Weak TLS, session fixation, missing CSRF tokens, and insecure cookies breach this clause.

If unresolved, these can result in fines up to €20 million or 4% of global turnover (European Union, 2016).

PCI DSS v4.0

- **Requirement 6.2** mandates timely patching of outdated software.
- **Requirement 8.3** calls for strong authentication (not evidenced here).
- **Requirement 10.6.1** expects logging and alerting mechanisms.
- **Requirement 6.5.10** requires mitigation of common injection risks (e.g., XSS).

Failing these standards jeopardises both cardholder data and commercial partnerships. The site's current state shows critical non-compliance that must be addressed to avoid breaches and legal consequences.

6. Conclusions

The assessment uncovered significant security weaknesses, including outdated software, weak session controls, insecure SSL/TLS configurations, and missing DNS protections. These gaps leave the system highly exposed to exploitation and reflect a lack of basic security hygiene.

Mapping these findings to GDPR and PCI DSS revealed both technical and regulatory non-compliance. Immediate remediation is essential to protect user data, prevent reputational damage, and ensure ongoing compliance with industry standards.

7. Recommendations (with Prioritization, Cost, and Timelines)

Priority	Action	Justification	Cost (Est.)	Timeline
High	Implement CSRF Tokens	Prevents unauthorized user actions	£500	Immediate (1 week)
High	Fix TLS Configuration	Align with GDPR & PCI	£350	1 week
High	Patch Apache Server	Avoid known CVEs	£400	3–5 days
High	Apply HSTS and Headers	Prevent downgrade & clickjacking	£250	1 week
Medium	Secure Cookies	Add Secure and HttpOnly flags	£150	2 days
Medium	Enforce Logging	Essential for breach detection	£600	1–2 weeks
Medium	Update DNS Records	Protect email domain from spoofing	£150	3 days
Low	Close SMB Ports	Not needed for public web apps	£0 (IT reconfig)	2 days
Low	Renew SSL Certificate	Ensure user trust	£100	Immediate



This timeline chart visually illustrates when each security fix is scheduled to be implemented, how long it will take, and its estimated cost. Colour coding helps prioritise actions — red (high), orange (medium), and green (low). The timeline aims to ensure that critical risks are addressed first within budget and time constraints.

A focused investment of £2,000 is recommended to immediately implement high-priority fixes that directly affect GDPR and PCI DSS compliance, including CSRF token setup, TLS configuration, Apache patching, and secure headers.

Medium and low-priority items, while less urgent, still pose risk and should be scheduled within 30 days. Addressing all recommendations promptly will significantly reduce exposure to data breaches, regulatory penalties, and loss of customer trust.

8. References

- European Union (2016) *General Data Protection Regulation (GDPR)*. Available at: <https://gdpr.eu/what-is-gdpr/> (Accessed: 3 June 2025).
 - Hertzog, R., Otsuki, J. and Stuermer, J. (2017) *Kali Linux Revealed: Mastering the Penetration Testing Distribution*. OffSec Press. Available at: <https://kali.training/downloads/Kali-Linux-Revealed-2021-edition.pdf> (Accessed: 3 June 2025).
 - Nmap.org (2023) *Nmap Security Scanner*. Available at: <https://nmap.org/> (Accessed: 2 June 2025).
 - OWASP (2021) *OWASP Top 10: The Ten Most Critical Web Application Security Risks*. Available at: <https://owasp.org/www-project-top-ten/> (Accessed: 2 June 2025).
 - PCI SSC (2022) *PCI DSS v4.0: Payment Card Industry Data Security Standard*. Available at: https://www.pcisecuritystandards.org/document_library?category=pcidss&document=pci_dss (Accessed: 3 June 2025).
 - PortSwigger (2023) *Burp Suite Documentation*. Available at: <https://portswigger.net/burp/documentation> (Accessed: 2 June 2025).
 - SSL Labs (2023) *SSL Test by Qualys SSL Labs*. Available at: <https://www.ssllabs.com/ssltest/> (Accessed: 2 June 2025).
 - ZAP Project (2023) *OWASP ZAP – Zed Attack Proxy*. Available at: <https://www.zaproxy.org/> (Accessed: 2 June 2025).
-